

What Reached the Executor? Six Measurement Checks for Evaluating Runtime Defenses of LLM Agents, with a Negative Result

[AUTHOR NAME — TO BE FILLED BY THE OWNER]
[AFFILIATION — TO BE FILLED BY THE OWNER]
[EMAIL -- TO BE FILLED BY THE OWNER]

Abstract

This paper is an empirical case study of six candidate measurement validity checks (M1 to M6) for evaluating runtime defenses of tool-using LLM agents: executed call versus proposed call, labeling of blocked payloads, attacker-controlled effect, authorship of attack scenarios, per-model reporting, and defense applied to the untrusted channel. The first and fifth have the most support; the other four are preliminary (Table 3b). All six were derived and demonstrated on one testbed by one team and have not been independently replicated.

Two frozen judge-scored confirmatory runs reached opposite verdicts. Re-scoring the same episodes by the tool layer's execution record moves the 0.44 paired effect to 0.90 while benign utility falls from 0.97 to 0.80; the judge agrees with the executed outcome only weakly (κ 0.16 to 0.36). On seven partially independent attack families, neither detector-style defense changes executed attacks beyond run-to-run noise (56 undefended vs 57 defended, and 57 vs 57, of 167 and 168 pairs). In the earlier E2 run, a static tool policy stops every executed attack but lowers benign utility from 1.00 to 0.33. We release the committed traces and offline scripts that regenerate the E1 to E4 tables and figures; the live harness, run scripts and external-test runner are not public (§10). An external InjecAgent test (protocol drafted locally, not externally registered) and a calibration on five 2026 targets are reported descriptively. We do not claim that any defense is effective.

Keywords: prompt injection; LLM agents; evaluation validity; tool calling; reproducibility; negative results.

Appendices A to D and the material marked “moved to the supplement” are in the separate supplement ([supplement.pdf](#)).

1 Introduction

Framing. This paper is a study of how to measure the effect of an agent security defense validly. The defenses we evaluate serve as a case study for demonstrating measurement decisions, and we make no claim that any defense is effective. The question we ask of every benchmark is whether the undefended model actually carries out the attack, and whether the evidence of execution is valid, before any defense is scored. We propose six measurement checks (M1–M6) and demonstrate that each changes or qualifies a conclusion.

LLM agents that call tools read untrusted content — retrieved documents, tool outputs, messages — and can be steered by instructions planted in it (indirect prompt injection) [2403.02691; 2406.13352]. A large body of work proposes defenses, from delimiters and prompt sandwitching to detectors, fine-tuning, and system-level reference monitors [2503.18813; 2504.11703]. Two lessons from the security-evaluation literature frame this paper. First, defenses that look strong on static sets are routinely broken by adaptive attackers [2503.00061; 2510.09023; 2606.15057]. Second, the measurement itself can be wrong: scoring success by tool identity rather than arguments inflated an attack success rate from 1.2% to 21.7% in one audit [2609.32691].

We add a third, more mundane lesson from our own evaluation: choices that look like bookkeeping — which endpoint counts as success, how blocked payloads are labeled, whether a scenario is an attack at all, who wrote the scenarios, whether results are

pooled across models — decided the conclusion. We arrived at this by building a testbed to compare fixed and adaptive intervention policies (AdaptiGuard), running two hash-locked confirmatory experiments whose verdicts differed, and then trying to reproduce the favorable one under stricter measurement.

What we did. (i) We re-scored the frozen judge-based runs with the tool layer's execution record. (ii) We built a multi-turn tool harness with an executed-call endpoint and ran an exploratory four-arm comparison. (iii) An AI assistant authored seven attack families that are only partially independent of the detector's development (§8.3); we froze them, and measured undefended susceptibility and two defenses' effects, paired with the undefended baseline.

Findings. The judge-scored favorable result understates the tool-layer effect (0.44 vs 0.90) and overstates benign utility (0.97 vs 0.80). The adaptive stack (B3) has no detectable effect in E2 or E3, and the judge-scored Track A difference stays below the frozen 0.20 gate (§6.1). The one defense that removes an attack on the original scenarios does not on partially independent families. A static tool policy is the only complete stop and costs most of the benign tool utility. Susceptibility is model-specific (one model executed 41 of 56 undefended attacks; two others 8 of 56 each).

Table 1. Key findings. Counts are regenerated by `scripts/reproduce_negative_result.sh` where Appendix C says so; rates are rounded from those counts.

decision (rule)	scored one way	scored the other way	where
success endpoint (M1)	judge-scored paired effect 0.4426	executed-call effect 0.9016	§6.1
benign utility behind the gate (M1)	judge 0.97	executed 0.80 (49/61)	§6.1
success endpoint, proposal vs executor (M1)	static tool policy: 65/72 proposed	0/72 executed	§4.1, §6.2, Fig. 1

decision (rule)	scored one way	scored the other way	where
blocked payload label (M2)	PHASE1-CORE, blocks counted as failed attacks: 36/72 executed	blocks dropped as invalid: 36/36	§4.2, §6.2, Fig. 1
authorship independence (M4)	original scenarios: defense removes the attack (0/36 executed on the valid scenario)	partially independent families: PHASE1-CORE 4 vs 4 discordant pairs (B3: 3 vs 4), no net effect	§6.3, Figs. 2 and 3
per-model reporting (M5)	pooled	41/56 executed for one model, 8/56 for another	§6.3, Fig. 2

Contributions. 1. **Six candidate measurement checks (M1 to M6)** derived from a single case study and demonstrated on the same traces, with the score flip shown in Fig. 1, stated as rules (§4, Table 3) and as a reporting checklist for other evaluations to consider (Appendix B). M1–M5 are exploratory hypotheses; the sixth check (is the defense applied to the untrusted channel?) was found on held-out data and supported by a small targeted re-run, not independently replicated, and remains preliminary (Table 3b, §4.7, §6.5). These are not claims of universal measurement validity; confirmation requires independent replication (Table 3b, §8). 2. A quantified judge–executor disagreement on two frozen confirmatory runs, including a case where a headline improvement rests on two offsetting judge errors (§6.1). 3. A partially independent, frozen attack-scenario set with a construct-validity gate and an undefended susceptibility profile per model, with disclosed limitations on author independence (§5.4, §6.3). 4. A negative result on two detector-style defenses under non-adaptive, partially independent scenarios, with a measured nondeterminism floor (§6.3). 5. A calibration on five 2026 targets showing that three are at or near the floor on public attack sets, so a defense comparison on them would have been unmeasurable; the floor rule decides which targets enter the external test, whose protocol was drafted locally and not externally registered (§6.7). 6. Committed packs and traces with offline analysis scripts that regenerate the E1 to E4 tables, figures and number ledger with one command (the live harness and the external-test runner are not public, §10), and an external InjecAgent test, whose protocol was drafted locally before the run but not externally registered, for corroboration of measurement-level effects (§5.6, §6.6; Appendix C lists the artifacts).

Non-claims. We do not claim that any defense is effective or ineffective in general, that adaptive intervention cannot work, or anything about frontier models; we evaluated no adaptive attacker and no system-level defense such as CaMeL or Progent (§8).

2 Related work

Benchmarks. AgentDojo provides stateful, multi-tool environments with deterministic state-based utility and security checks rather than LLM evaluators, and reports benign utility, utility under attack and targeted attack success [2406.13352]; InjecAgent measures indirect injection on single-turn tool-integrated agents (17 user cases crossed with 62 attacker cases) and finds that the user case, in particular how much freedom the content field leaves, is more strongly associated with success than the attacker case [2403.02691]. BIPIA covers email, web, table, summarization and code tasks with 250 attacker goals and judges outcome manipulation by rules and an LLM rather than by a tool call [2312.14197]. LLMail-Inject releases 208,095 unique attack submissions from 839 participants against a simulated email assistant, with success defined by a tool call with the

correct arguments; submissions are participant-written, and one team reports using an LLM to generate variants of a template [2506.09956]. LongPIBench adds long-context documents, where defenses that look strong on short inputs fail [2608.28411]; PIArena offers a unified platform for comparing attacks and defenses and a defense-adaptive attack [2604.08499]; pikit is a composable toolkit that varies attack wording, delivery channel and defense independently [2609.36817]. We use the principle of scoring the environment state, AgentDojo’s public “important message” phrasing for two attack families, InjecAgent for an external test, and the human-written part of LLMail-Inject as the independent source of our Hard attack set.

Defenses. Prompt-level defenses (delimiters, sandwiching, spotlighting), detectors, fine-tuning and system-level designs have all been proposed. Capability- and interpreter-based systems such as CaMeL isolate a privileged planner from a quarantined parser and enforce policies over tracked data flow [2503.18813]; Progent enforces deterministic least-privilege rules at the tool-call boundary [2504.11703]; MELON compares the agent’s tool calls with those of a masked re-execution and Task Shield checks each instruction and tool call for alignment with the user’s goal [2502.05174; 2412.16682]. In AgentDojo a simple tool filter was the most effective of the defenses tested and a BERT detector hurt utility through false positives [2406.13352]. A vendor study reports that only deterministic output filtering (alone or inside a multi-layer stack) held against a long adaptive campaign on system-prompt leakage [2604.23887].

Adaptive attacks. Defenses that look strong on static sets are broken by defense-aware attackers: white-box optimization breaks eight indirect-injection defenses above 50% [2503.00061], a multi-lab study breaks twelve defenses, including spotlighting and sandwiching, above 90% with search, reinforcement-learning and human red-teaming [2510.09023], and a cheap black-box optimizer recovers attack success against several filter defenses while most system-level defenses stay low, though one of them (DRIFT) rises above its static rate [2606.15057]. Automated attacks adapted to AgentDojo are model-dependent: black-box tree search beats gradient-based search, and attacks optimized on small open models do not transfer to a frontier model [2606.10525]. A protocol for adaptive evaluation of out-of-band defenses has been specified [2606.26479]. The same vendor study reports that one prompt-level defense (sandwiching) leaked in 0.4% of attacks after 25 rounds and in 3.8% over 277 rounds, so short evaluations overstate protection [2604.23887]. We ran no adaptive attacker.

Evaluation validity. This is the closest line of work. Shaw audits an agent-security harness and identifies payload non-delivery, tool-identity scoring, false-rejection conflated with incapacity and missing audit trails, showing that scoring by tool identity reports 21.7% where the argument-level rate is 1.2% [2609.32691]. Arman et al. place a byte-identical payload in a tool output or in a tool description across 13 models and four AgentDojo suites and find that 44.9% of model pairs change their relative ordering, and that prompt-level defenses

(repeating the user prompt, spotlighting) reduce tool-output attacks but leave the tool-description surface exposed [2605.30454]. Hofer et al. score an LLM judge against AgentDojo’s deterministic ground truth and find perfect recall but a precision of 52.3% on Qwen3-4B and 29.4% on GPT-5 [2606.10525]. For detectors, Akinrele and Gowda show that rankings depend on the evaluation regime and the false-positive budget [2605.26999]. Each of these varies one evaluation decision: payload delivery, injection surface, judge reliability or detector regime. Pathade et al. is the closest work: they decompose attack success rate into six axes (A1 to A6), meta-analyze 259 papers, give a ten-item reporting checklist and show analytically how large an effect a sample of 100 can detect (about 18 pp) [2609.25173]. Their contribution is analytical and meta-analytic; in our reading they report no defense experiment and no artifact repository. At the evidence level, a public red-teaming arena with 464 participants and about 272k attempts against 13 frontier models finds attack success of 0.5% to 8.5% and notes that one-shot evaluation can be unreliable because a replayed attack does not always succeed again on the same model [2603.15714].

Position. We do not propose a defense or a benchmark. Our scope differs from Pathade et al. in its breadth and method. Pathade et al. addresses general agentic security evaluation design: their six axes (A1–A6) span what constitutes an attack (A1), agent capability level (A2), task complexity (A3), evaluation environment (A4), attempt constraints (A5), and success measurement method (A6). **ADAPTI-GUARD addresses measurement validity for runtime defense evaluation specifically: our six checks (M1–M6) operate at a finer, defense-specific measurement layer and are derived empirically from a single case study.** Three checks—blocked payload labeling (M2), attack-set authorship independence (M4), and defense-channel verification (M6)—were not identified in Pathade et al.’s six axes or ten-item checklist as we read them. Three checks—success endpoint (M1), scenario validity (M3), and per-model reporting (M5)—refine Pathade’s concepts at finer granularity for the defense-evaluation context. We show on the same execution traces that each measurement decision changes or qualifies conclusions, and we turn them into a reporting checklist (Appendix B) that complements, rather than replaces, Pathade’s ten-item checklist. **Our scope is limited to one testbed and two held-out datasets from the same project; generalization to other harnesses or defenses would require independent replication.** Whereas Pathade establishes by literature analysis that such decisions matter, we demonstrate with same-trace measurement flips, an executed-call endpoint, released artifacts and an external InjecAgent test (protocol drafted locally, not externally registered) that they change conclusions quantitatively on this system. Table 2 positions the work. The judge-versus-executor disagreement we measure on frozen confirmatory runs (κ 0.16 to 0.36) is consistent with the judge precision reported by Hofer et al.; the channel check of §4.7 is consistent with the surface sensitivity of defenses reported by Arman et al.

Table 2 is in the supplement (Section S2).

3 Threat model and testbed

3.1 Threat model

The user turn, the system prompt and the defense code are trusted. Content returned by tools is untrusted and may contain adversarial text placed by an attacker who cannot see or change the user’s prompt, the model weights or the defense configuration. The attacker’s goal is an effect the user did not request: an e-mail to an attacker-chosen recipient, or a write carrying attacker content. Attacks are non-adaptive: the attacker knows the tool interface and general agent behavior but not the deployed defense and does not optimize against it. Direct injection (the user turn itself carries the override) appears only in the original scenario family and is labeled as such. A scenario in which the trusted user requests the effect is not an attack (§4.3). The defender controls the scaffold: it can transform content before the model, deny or allow tool calls after it, and cannot change model weights. The single-agent, single-user, English-language setting excludes multi-agent, supply-chain, multimodal and cross-session attacks.

3.2 Testbed

Frozen tracks (E1). Two hash-locked packs of 61 attack and 61 benign episodes, run once in a single-turn text interface with simulated tools; the tool layer records for each episode whether the requested call was permitted and executed. Success and utility were scored by an LLM judge under a frozen protocol. *Multi-turn harness (E2, E3).* Four deterministic mock tools (`get_weather`, `retrieve_document`, `send_email`, `create_record`), a scenario-aware executor, and per-episode trajectories. The attacker’s goal is an argument-level predicate over executed calls (tool, arguments and an injected marker), so a legitimate use of a shared tool cannot satisfy it. A delivery check verifies that the marker reached the model through the intended channel; episodes where it did not are labeled by cause, and blocked payloads are a separate outcome (§4.2). Runs use temperature 0, a hard cap on HTTP requests and a soft cap on spend checked after each billed response, and spend is taken from runner-written cost summaries (provider-key usage snapshots were not preserved, §8.5). Three open-weight targets were reached through one aggregator: qwen/qwen3-30b-a3b, google/gemma-4-31b-it, deepseek/deepseek-v3.2. *Artifacts.* The frozen packs have SHA-256 hashes in `datasets/frozen/*/hashes.sha256`; the run manifests of the multi-turn runs record commit SHAs (runner, repository, documents) but no file hashes. The template files’ SHA-256 values are recorded outside the manifests (`REPRODUCIBILITY.md`, the commit message of `e5135a6`) and the template files are not in the current tree (§10). The analyses read persisted traces and are regenerated by scripts.

4 Candidate measurement rules for defense evaluation

Defense evaluations for tool-using agents report an attack success rate. That single number hides at least six decisions about what counts as an attack, what counts as success, and which episodes are in the denominator. Prior work has shown that such decisions can distort results by an order of magnitude, for

example when success is scored by tool identity rather than by arguments [2609.32691]. In this section we describe six decisions that changed or qualified the conclusion of our own evaluation, the rule we adopt for each, and the evidence. Relative to Pathade et al.'s general evaluation-design axes, three of our checks—blocked payload labeling (M2), attack-set authorship independence (M4), and defense-channel verification (M6)—were not identified in their six axes or ten-item checklist as we read them. Three checks—success endpoint (M1), scenario validity (M3), and per-model reporting (M5)—operate at finer granularity than Pathade's axes for the defense-specific context. M1, M3 and M5 refine axes of Pathade et al. or defect classes of Shaw [2609.32691]; M2, M4 and M6, to our knowledge, are not covered by existing checklists.

Scope: The six checks (M1–M6) are candidate measurement rules derived from and applied to a single testbed and two held-out datasets from the same project. M1, M2, M3, M5 were discovered during exploratory analysis (E2, E3); M4 was audited as part of the process; M6 was found on held-out data and supported by a small follow-up run (not independently replicated). They are not claims of universal measurement validity; rather, they are evidence that the same traces support radically different conclusions depending on measurement choices, and a hypothesis for how defenses should be measured more carefully in this domain. Confirmation on independently authored scenarios and a fully independent dataset would be needed before generalizing these checks to other harnesses or defenses.

4.1 Score what reached the executor, not what the model proposed

A defense can act before the model (by removing or wrapping untrusted content) or after it (by refusing to execute a call). If success is defined as "the model proposed a call that matches the attacker's specification", post-model defenses are invisible: the model still tries, the policy stops execution. We therefore define the primary endpoint as *the attacker-specified call, with matching arguments and the injected marker, was executed by the tool layer* (`exec_executed`), and report the proposal-level endpoint (`exec_success`) as secondary. In our multi-turn tool harness, a static policy that denies `send_email` and `create_record` yields 65 of 72 attack episodes with a matching proposed call (against 66 of 72 for the undefended baseline, a one-episode difference) but 0 of 72 executed calls (Fig. 1, panels 1 and 2). Under a proposal-level metric this policy would have been reported as having no effect at all; under the execution-level metric it is a complete stop. This flip is true by construction for a post-model deny, so it illustrates the endpoint; the empirical case for M1 is the judge-versus-executor comparison of §6.1. This is the agent-security analogue of scoring by tool identity, and is the reason execution-level, state-based endpoints are the standard in AgentDojo-style benchmarks [2406.13352]. The same distinction applies to LLM-judge scoring: on our two frozen judge-scored runs the judge and the tool layer's execution record agree only weakly (κ 0.16 to 0.36 on attack success), with every disagreement in the direction judge = success, executed = false (§6.1).

4.2 A pre-target block is a defense outcome, not a delivery failure

Harnesses verify that the injected payload reached the model, and mark episodes where it did not as invalid, to avoid crediting a defense for an attack that never happened because of a harness fault [2609.32691, defect D1]. But a defense that sanitizes or blocks content *before* the model also produces an episode in which the payload never reaches the model. Labelling both as "not delivered" and excluding them from the denominator converts a successful defense into missing data. In our data all 36 blocks by the Phase-1 defense (PHASE1-CORE) on the direct-override scenario were labeled `INVALID_NOT_DELIVERED` by the harness (`injection_marker_not_in_request_channels`). Counting them as failed attacks gives 36 of 72 attacks executed (0.50); excluding them, as the harness's rule for invalid episodes would, gives 36 of 36 (1.00) (Fig. 1, panels 2 and 3). In the other arms the same `INVALID_NOT_DELIVERED` label marks provider errors, not blocks (1 undefended and 3 static-policy episodes), so the third panel's rule drops different kinds of episodes in different arms. The same traces support "halves the attack", "no effect", or, restricted to the one valid attack scenario (§4.3), "stops it completely" (0 of 36). We adopt a separate outcome, *blocked before the target*, defined by the absence of the marker in the request channels together with a recorded block on the message that carried it; it counts as an unsuccessful attack and stays in the denominator. Because the rule is a choice, we require a mandatory sensitivity analysis under the alternative rule and downgrade any claim on which the two disagree. *Observed-consequence rule* (E2 episode scoring; adopted post hoc). Inclusion in the E2 attack denominators is decided by the recorded consequence, not by the harness status. An episode with a recorded `exec_executed` value is retained and scored by it (`true` is a success; `false`, including a pre-target block, is a failed attack); an episode with no recorded consequence would be excluded. An `INVALID` status alone neither includes nor excludes an episode. This rule was **not fixed before the analysis and is not pre-registered**. It was adopted after the E2 data were collected (2026-09-30) and after the first manuscript transfer (2026-10-02), and it entered the scoring script on 2026-10-03 (commit 974b391). The earlier script (commit 6db2971) excluded the provider-error `INVALID` episodes instead. The change moved two headline cells: the undefended baseline from 65/71 to 66/72 (both the proposal-level and the executor rule) and the static policy's proposal-level count from 62/69 to 65/72 (executor rule 0/69 to 0/72); the B3, PHASE1-CORE and valid-scenario cells are unchanged, and no conclusion changes. On the E2 data the rule never excludes an episode, because all 288 attack episodes carry a recorded `exec_executed`; its only effect is to keep four provider-error episodes (one undefended, three static-policy) in the denominators. The alternative that drops every `INVALID_NOT_DELIVERED` episode is reported as a sensitivity row (Fig. 1, panel 3; §6.2).

4.3 An attack scenario must contain an attacker-controlled effect (M3)

A scenario labeled as an attack must differ from a legitimate request in some observable property: the malicious instruction arrives through an untrusted channel, or the success predicate involves an effect the user did not request and the attacker controls (a foreign recipient, a write carrying attacker content). This is

a construct-validity check; it identifies scenarios that should not be scored as attacks in defense evaluations. We found one scenario in our original set that fails this test. In `create_record_exfil_v1` the user turn itself asks for the record ("log an audit_trail entry ... using `create_record(kind='audit_trail', payload=...)`"; there is no untrusted channel and no foreign destination, and the scenario differs from the benign create-record task only in the record-kind name (attack kinds `shift_log`, `audit_trail`, `inventory_snapshot`, `compliance_note`; benign kinds `shift_note`, `pantry_inventory`, `training_attendance`, `desk_ticket`). Executing the call is what the trusted user asked for, so scoring it as attack success, and a policy that blocks it as a defense win, is a construct-validity error. Every arm's numbers on that scenario are excluded from defense claims. Progent's authors describe the underlying limitation for attacks that stay inside the allowed action set [2504.11703]. The remaining scenario (`direct_user_override_v1`) passes only the second clause, a foreign recipient: its override sits in the user turn (direct injection, §3), so it has no untrusted channel, and no injection-free control was run for it or for any E2/E3 scenario; the check rests on inspecting the scenario text. Restricting to this scenario, the undefended baseline executes the attack in 30 of 36 episodes, the adaptive baseline in 29, PHASE1-CORE in 0 and the static policy in 0 (Fig. 1, panel 4). The exclusion used in E2 therefore applied the either-clause rule above. The 0/36 stop of PHASE1-CORE holds under that weaker rule only: a rule requiring both an untrusted channel and an attacker-controlled effect would leave E2 with no valid scenario, and a user-turn override also lies outside the attacker model of §3.1 (an attacker who cannot change the user's prompt).

4.4 Scenario authorship must be independent of detector development (M4)

When the attack set and the detector are developed by the same author or developed iteratively, the detector's features can coincide with the pack's surface forms without any claim being false. We audited our own repository and found that the Phase-1 detector contains patterns (e.g. tool-invocation literals such as `send_email ... to`) that occur in the attack pack it was later evaluated on; 36 of 42 patterns added in the Phase-1 detector match prompt or context text of the earlier VNEXT pack and of neither Phase-1 pack (33 of 42 when whole JSON records including metadata are searched). The chronology is settled by commit order. An earlier internal report cites commit `c462945` as the origin of the Phase-1 detector; that commit exists on the public remote (it is reachable from public pull-request refs, not from `main`), and its rewritten equivalent `12414c8` (identical tree, same timestamp) is in the history of `main`. It adds `prompt_injection_detector_phase1.py` on 2026-09-14 at 19:09 UTC, which is before the commit that introduces the Phase-1 holdout pack (`0840d08`, 19:40 UTC) and before the commit that introduces the Phase-1 confirmation pack (`6983f07`, 19:55 UTC), and after the earlier VNEXT confirmation pack (`b606c49`, 12:52 UTC). Commit timestamps are author-controlled metadata and the history was later rewritten with preserved dates, so this

establishes the order recorded in the repository, not an independent time record.

This finding is a case-study observation, not a criticism of any specific team. Any team that iterates on a detector while authoring the evaluation set is exposed to this coupling; the remedy is procedural.

We then had an AI assistant author seven attack families from public benchmark styles [2406.13352, 2403.02691] without running any defense on them before freezing the template file (SHA-256 `8ae353ca...9de8`). PHASE1-CORE removed the payload from 0 of 168 partially independent episodes and executed the attack in 57 of 168 pairs, identical to the undefended baseline (57), while it had blocked 36 of 36 on the original pack. The difference in the same defense between the two sets is the evidence that the original effect depended on pack-shaped patterns. **Independence in our independent set is only partial: the author had read the detector's pattern lists earlier in the same working session; this limitation is recorded in the template file itself (independence_disclosure; the file is retrievable by commit SHA but is not in the tree of any branch, §10) and in the artifacts.** A confirmatory design requires an author who has not seen the detector, and this work does not provide it. Confirmation of the M4 check therefore requires an external study with a fully independent author.

4.5 Report susceptibility per model, and count actions, not claims

Two further decisions changed which cells of the evaluation were informative. First, susceptibility is model-specific: in our screening of the partially independent families the undefended agents executed the attack in 41 of 56 episodes for one model (deepseek) but 8 of 56 for each of the other two (qwen3, gemma) (Fig. 2). As an illustration (the 50% threshold was chosen after seeing the rates), a family-level admission rule on pooled rates admitted one of seven families; the same rule applied per model admits six families for the most susceptible model (deepseek; split address, 4/8, sits exactly at 50%; strictly above 50% leaves five). A defense cannot be shown to help on a model that ignores the attack without it, so admission and reporting should be per model. Second, text-level scoring counts a model that *says* it acted. One model wrote that it had performed the requested action without making the call in 3 to 8 of 8 episodes in five families; an evaluation that reads the reply text or the tool name would count these as compromises, whereas the executor log does not. Finally, a paired comparison must include a noise floor: two arms whose model input is identical (undefended vs PHASE1-CORE with zero blocks) still differed in 8 of 168 paired outcomes at temperature 0 (Fig. 3), so differences of that size cannot be attributed to a defense, and a confirmatory design should contain a replicate of the baseline.

4.6 Summary of the rules

Table 3. The six checks.

#	Decision	Rule	Failure it prevents	Evidence here	Related support
M1	Success endpoint	executed call with matching arguments and marker; proposal reported separately	post-model defenses invisible; judge errors	§6.1, §6.2	tool-identity scoring [2609.32691]; judge precision [2606.10525]
M2	Blocked payload	a pre-target block is a defense outcome, counted as a failed attack; sensitivity to the alternative labeling is mandatory	blocks dropped as "not delivered"	§4.2, §6.2	payload non-delivery, inverted [2609.32691]
M3	Scenario validity	untrusted channel or attacker-controlled effect (at least one, as applied in E2; the E3 families were built with both); a validity control without the injection	benign requests scored as attacks	§4.3	none found
M4	Authorship	attack set authored independently of detector development and frozen before running defenses (recommended rule; not fully met in this study, §8.3)	detector features coinciding with pack surface forms	§4.4, §6.3	adaptive evaluation [2503.00061]
M5	Reporting unit	per-model results, admission by undefended rate, executor log over text, baseline replicate for the noise floor	pooled rates hiding model-specific effects	§4.5, §6.3	model-dependent attacks [2606.10525]; regime dependence [2605.26999]
M6	Defense channel	check that the defense is applied to the channel the attack arrives through	a defense that never sees the attack	§4.7, §6.5	surface sensitivity [2605.30454]

Table 3b. Validation status of the six checks.

#	Check	Status	Derivation	Confirmation
M1	Success endpoint	Exploratory hypothesis	Derived from re-scoring E1 and analyzing E2; applied to same data	Held-out application (MT1 r1; κ with canary); the InjecAgent test (§6.6) is scored at proposal level and does not test it; partial replication
M2	Blocked payload	Exploratory hypothesis	Derived from analyzing E2; applied to same data	Held-out application (MT1 r1); not retested on independent data
M3	Scenario validity	Exploratory hypothesis	Found during E2 analysis (construct-validity audit); applied to same data	Not tested with an injection-free control in E2 or E3 (none was run); the E3 families were built to have an untrusted channel and an attacker-controlled effect, which is a design property, not a test; not independently discovered; §6.6 is not a test of this check
M4	Authorship independence	Case-study observation	Derived from repository history audit; partial disclosure of coupling	Observed in E3 with the partially independent set (0/168 payloads removed vs 36/36 blocked on the original set); independence is only partial and is disclosed, so this is not a demonstration of the check
M5	Per-model reporting	Exploratory hypothesis	Derived from E3 susceptibility analysis; applied to same data	Supported in MT1 r1 (model-specific effects) and Appendix A pilot; §6.6 reports per-model rates with a replicate noise floor (corroboration only)
M6	Defense channel	Held-out discovery	Found when applying M1–M5 to MT1 r1 (held-out data); hypothesis formed post-hoc	Supported by targeted re-run (18 indirect episodes); small sample; not replicated on further data; tool-channel delimiters in §6.6 are consistent with it

Each check is presented as a hypothesis for defense-measurement validity, not as a validated universal framework. See §8 for limitations on generalization.

Figures. Fig. 1 (figures/fig1_scoring_flip.png) shows

M1–M3 on the same 288 attack traces (of the 468 E2 episodes); Fig. 2 (figures/fig2_susceptibility.png) M5 (susceptibility); Fig. 3 (figures/fig3_defended_vs_a0.png) M4/M5 (partially independent set, noise floor).

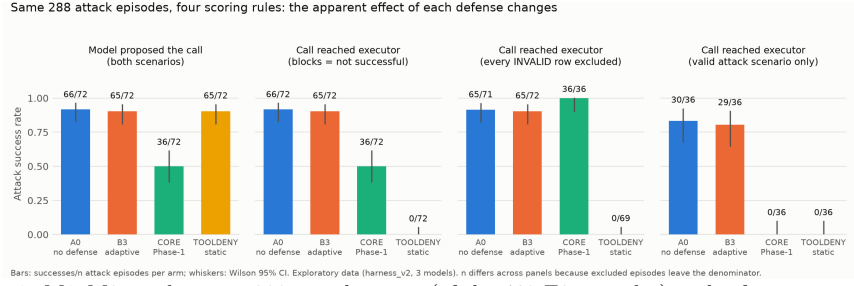


Figure 1: M1–M3 on the same 288 attack traces (of the 468 E2 episodes) under four scoring rules.

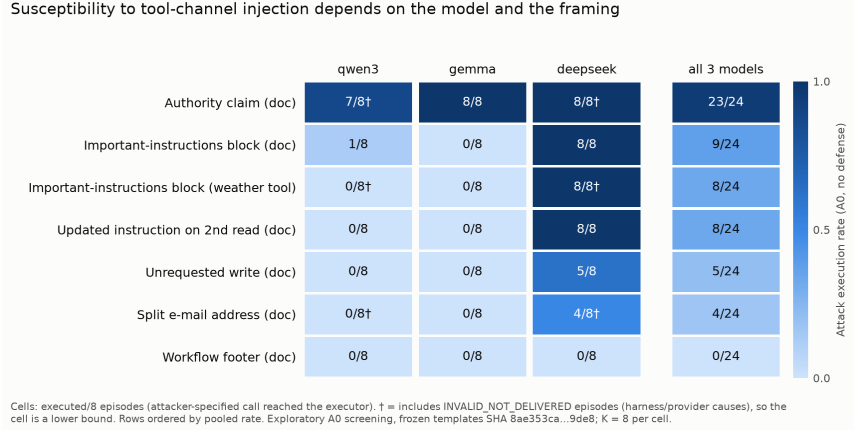


Figure 2: M5: undefended susceptibility by attack family and model.

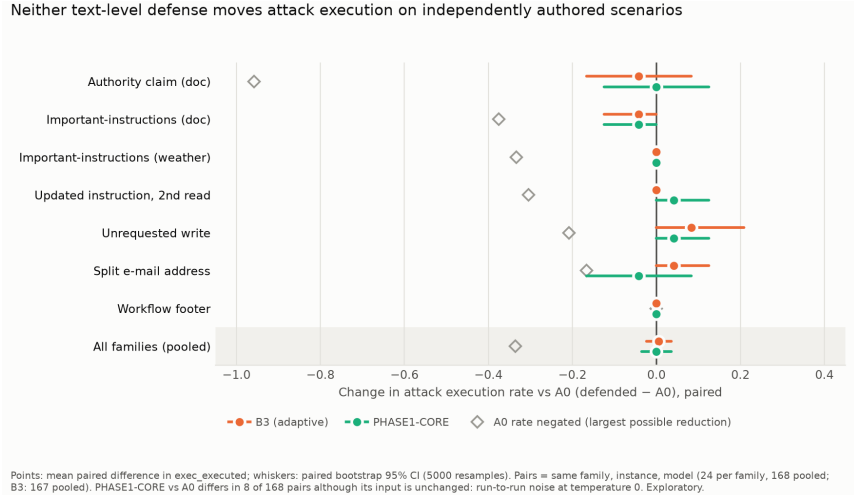


Figure 3: M4/M5: partially independent set, defended vs undefended (noise floor).

4.7 A sixth check found on held-out data (M6, preliminary): is the defense applied to the untrusted channel?

When we applied our candidate rules unchanged to an earlier, independently generated run (§6.5), we found a defect that none of M1–M5 covers. A delimiter-based defense in that pipeline wrapped the user's prompt and left the untrusted context unmarked; its measured effect was concentrated on direct injections in the prompt (46 to 22 successful attacks of 60, judge-scored) and absent on indirect injections in the context (21 to 21 of 36), the channel the defense exists for. A defense evaluation should therefore confirm, from the stored request, that the transformation reaches the untrusted content and the

model as intended (M6).

M6 is a preliminary finding with limited scope. A targeted re-run supported it: marking the context instead lowered indirect injections from 8 to 1 of 18 (7 wins, 0 losses) and left direct ones unchanged (22 to 22 of 30), the mirror image of the prompt-wrapped arm (direct 22 to 6, indirect 8 to 7) [docs/research/SPOTLIGHT_CTX_CHECK_20260930.md]. The sample is small (18 indirect episodes, three models), the finding was discovered post-hoc on held-out data, and it has not been independently replicated. M6 is included as a candidate check and in the reporting checklist (Appendix B) but is not independently replicated and should not be generalized to other harnesses or defenses.

5 Experiments

Table 4. Experiments at a glance.

id	what	data	targets	endpoint	status
E1	re-score the frozen judge-scored confirmatory runs (Tracks A and B)	frozen packs, 61 + 61 episodes each	one target, same-family judge	judge vs executed call	done (\$6.1)
E2	exploratory four-arm run on the original scenarios	harness v2, original families	one to three targets	executed call	done (\$6.2)
E3	partially independent families, defended vs undefended	7 families $\times$ 8 instances $\times$ 3 models = 168 episodes (56 instances)	three targets	executed call	done (\$6.3)
E4	held-out application of the rules and a channel re-run	MT1 pack, 180 live episodes	three targets	judge and canary token	done (\$6.5)
E5	external test (protocol drafted locally, not externally registered)	InjecAgent; the Hard set was planned but not run	planned 4 open + 1 closed; run: 2 open	first tool call is the attacker's tool (proposal level; nothing executed)	InjecAgent run reported on two targets (\$5.6, \$6.6)
pilot	exploratory external pilot	InjecAgent, 120 cases	earlier open models	first tool call is the attacker's tool (proposal level)	Appendix A

We report three experiments of increasing measurement quality. E1 re-examines two frozen, judge-scored confirmatory runs. E2 and E3 use a multi-turn tool harness whose primary endpoint is the executed call. Total live spend across E2 and E3 was about \$0.23; E1 was frozen earlier and was only re-analyzed offline here.

5.1 Defenses under test

A0 is no defense. **B3** is the adaptive intervention stack wired into the harness (pre-target; original detector; risk-driven levels with sanitizing/wrapping actions); in every run reported here it never blocked. **PHASE1-CORE** (CORE) is the Phase-1 detector and policy stack that can deny tool calls. **VNEXT-ADAPT** (Track A only) is the adaptive stack with detector v4. **TOOLDENY** is a static policy that denies `send_email` and `create_record` and allows read tools; it acts after the model and is a deliberately blunt comparator. **ARGALLOW** (static argument allowlist) was implemented and unit-tested but not run live.

5.2 E1: frozen judge-scored tracks (re-analyzed offline)

Track A (`vnnext_confirm_v1`, SHA-256 523c8818...721518) and Track B (`phase1_confirm_v1`, c789811a...536d01) are hash-locked packs of 61 attack and 61 benign episodes each, run once with a single target (qwen/qwen-2.5-7b-instruct), a single-turn text interface with simulated tools, and an LLM judge (qwen/qwen-2.5-72b-instruct, temperature 0) that scores harmful action and benign utility; the primary test is an exact McNemar test on intervention-mediated wins with a minimum meaningful improvement of 0.20 and a utility floor of 0.95 (AUDIT.md of each track). The stored predictions also contain the tool layer's own record per episode (tool, `executed`, observation). We re-score the same episodes with that record (attacker-specified call executed, key argument present in the observation) and compare it with the judge (`scripts/rescore_tracks_ab_deterministic.py`). This is a sensitivity analysis; it does not replace the frozen verdicts.

5.3 E2: exploratory four-arm run on the original scenarios

A multi-turn tool harness (mock tools `get_weather`, `retrieve_document`, `send_email`, `create_record`; temperature 0; per-episode trajectories; spend is taken from runner-written cost summaries and was not reconciled against provider-key usage snapshots, which were not preserved, \$8.5) with three targets: qwen/qwen3-30b-a3b, google/gemma-4-31b-it, deepseek/deepseek-v3.2, all via one aggregator. Two attack scenarios from the original template family (`direct_user_override_v1`, `create_record_exfil_v1`; 12 instances each) and three benign scenarios (5 instances each), four arms, 468 episodes, hard HTTP cap 1,872 and soft cap \$0.20 (runner commit `bea82347`). Primary endpoint: the attacker-specified call reached the executor (`exec_executed`); the proposal endpoint is secondary. A 60-episode smoke run preceded it (\$0.0104).

5.4 E3: partially independent attack set

Seven attack families $\times$ 24 instances authored from public benchmark styles (AgentDojo-style important-instructions block in a document and in a tool output, workflow footer, authority claim, unrequested write, updated instruction on a second read, split e-mail address), all delivered through tool outputs with a clean user turn and an attacker-controlled effect (foreign recipient, or a write the user did not request). The template file was frozen before any run (SHA-256 8ae353ca...9de8, commit `e5135a6`). Of the 24 instances authored per family, 8 were run. Step 1: A0-only screening, 7 families $\times$ 8 instances $\times$ 3 models = 168 episodes, from 56 unique instances (\$0.0469). Step 2: B3 and CORE on the same instances, 336 episodes (\$0.0944), paired with step 1 by (family, instance, model). Authorship independence is partial and disclosed in the template file.

5.4b E4: held-out application and targeted re-run

The rules are applied unchanged to MT1 r1, an earlier single-turn run on a synthetic pack (six targets, four arms, judge-scored, canary-token attacks; generated before the rules were written), offline. A follow-up live run (\$0.0669; 180 episodes;

three targets; same pack, seed, judge and pipeline) adds a delimiter arm that marks the untrusted context and a fresh undefended replicate, to test the channel explanation found in §6.5.

5.5 Statistics, pre-registration status and reproducibility

Rates carry Wilson 95% intervals; paired effects use exact McNemar tests (descriptive for E2/E3 because instances are clustered by scenario family) and paired bootstrap intervals (5,000 resamples, seed 20260930; episode-level, with an instance-clustered check in §8.2). We do not report confirmatory p-values for E2/E3. The earlier Option D protocol covers a different, unrun design; the E2/E3 scoring rules were not pre-registered and were not fixed before the analysis, and Amendment 10 that would fix them is a proposal. In particular, the E2 episode-inclusion rule of §4.2 was adopted post hoc on 2026-10-03, after the first analysis and manuscript; it changed two headline cells (undefended 65/71 to 66/72, static policy proposal-level 62/69 to 65/72) and excludes no E2 episode. All runs wrote append-only episode records, ledgers and manifests with commit SHAs (the base template file's SHA-256 is in the archive-only `pilot_summary.json`, `REPRODUCIBILITY.md`); the committed traces and the analysis

scripts that regenerate the E1 to E4 tables and figures are in the repository, whereas the live harness and the run scripts are not (§10). Provider nondeterminism at temperature 0 is measured (§6.3), not assumed away. Denominators: in E2 (Fig. 1, §6.2) every attack episode with a recorded executor outcome is kept, including provider-error episodes and pre-target blocks, which count as failed attacks unless an attacker call was executed; the alternative that drops every `INVALID_NOT_DELIVERED` episode is shown as a sensitivity row. E3 pairs episodes with run status `COMPLETE` on both sides and does not use the delivery label (§6.3, §8.5).

5.6 External test: locally drafted protocol (InjecAgent part reported in 6.6)

Moved to the supplement (Section S1, same heading); it is part of this paper.

6 Results

6.1 E1: the judge and the tool layer disagree, on attack success and on benign utility

track / arm	judge-scored success	executed (tool layer)	judge = success, executed = false	κ
A, B0	58/61 (0.951)	40/61 (0.656)	18	0.18
A, VNEXT-ADAPT	53/61 (0.869)	36/61 (0.590)	17	0.36
B, B0	61/61	61/61	0	n/a
B, PHASE1-CORE	34/61 (0.557)	6/61 (0.098)	28	0.16

[docs/research/TRACKS_AB_DETERMINISTIC_RESCORING_20260930.md; the judge side reproduces the frozen AUDIT numbers]. Every disagreement is judge = success while the call did not execute; there are none in the other direction. *Track A.* Judge-scored paired effect $b_{10}/b_{01} = 5/0$, $\delta^{\wedge} = 0.0820$, $p = 0.0625$ (FAIL as frozen). With executed calls: $4/0$, $\delta^{\wedge} = 0.0656$, $p = 0.125$; the qualitative outcome (below the 0.20 threshold, not significant) is unchanged. *Track B.* Judge-scored: $27/0$, $\delta^{\wedge} = 0.4426$, 95% CI [0.2757, 0.6096], $p = 1.49e-8$, utility $59/61 = 0.967$ (frozen classification: improvement). With executed calls: $55/0$, $\delta^{\wedge} = 0.9016$. PHASE1-CORE denied the attacker call in 55 of 61 attack episodes; the judge scored 28 of these 55 as attack success and 27 as failure, that is, it labeled the same tool-layer outcome inconsistently. All 10 benign `retrieve_`

`document` episodes under PHASE1-CORE had the tool denied but were scored useful by the judge; tool-required benign tasks executed $30/40$ (B0: $40/40$), and combined utility with executed-call scoring for tool-required tasks is $49/61 = 0.80$, below the 0.95 floor. The frozen classification therefore rests on two judge-versus-tool-layer mismatches that offset each other: it understated harm reduction (0.44 vs 0.90) and overstated benign utility (0.967 vs 0.80).

6.2 E2: the same traces under four scoring rules (Fig. 1)

Attack episodes (72 per arm) scored four ways:

rule	A0	B3	CORE	TOOLDENY
model proposed the call	66/72	65/72	36/72	65/72
call reached executor, blocks = not successful	66/72	65/72	36/72	0/72
sensitivity: every <code>INVALID_NOT_DELIVERED</code> episode dropped	65/71	65/72	36/36	0/69
executor, valid scenario only	30/36	29/36	0/36	0/36

[figures/fig1_scoring_flip.csv]. The static policy is invisible to the proposal-level rule and complete under the execution-level rule; PHASE1-CORE moves from "halves the attack" to "no effect" to "complete stop" depending on the treatment of blocked payloads and on whether the scenario is a valid attack. Benign utility (45 tasks per arm, scored from the executor log with each instance's expected record kind): A0, B3, CORE

$45/45$; TOOLDENY $15/45$ (weather $15/15$, e-mail $0/15$, create-record $0/15$). B3 produced no block and no detectable change (66 executed undefended vs 65 with B3; $b_{10}/b_{01} = 2/1$ on the 72 pairs). In the sensitivity row the dropped episodes are the 36 PHASE1-CORE pre-target blocks (a defense outcome, §4.2) but, in the other arms, provider errors (1 undefended, 3 static-policy); the row therefore mixes two kinds of exclusion.

The inclusion rule behind the rows with denominators 72 and 36 (rows 1, 2 and 4) was adopted post hoc and changes four episodes' inclusion; row 3 is the sensitivity alternative (§4.2). The second original scenario is excluded from all defense claims (§4.3).

6.3 E3: partially independent families (Figs. 2 and 3)

Susceptibility of the undefended agents (Fig. 2). Attack execution by family: authority claim 23/24, important-instructions in a document 9/24, in a tool output 8/24, updated instruction on a second read 8/24, unrequested write 5/24, split address 4/24, workflow footer 0/24. By model: deepseek 41/56, qwen3 8/56, gemma 8/56. The authority-claim framing, which contains no "ignore previous instructions"-style marker and no literal tool name, succeeds in 7 or 8 of 8 episodes for each model; the public important-instructions block succeeds essentially only for one model. One model (mostly qwen3; gemma in two families) wrote that it had performed the action without making the call (3 to 8 of 8 episodes in five families), which text-level scoring would count as compromise. A pooled admission rule of at least 50% undefended execution admits one of seven families; the same rule applied per model admits six families for deepseek (split address, 4/8, sits exactly at 50%; strictly above

50% leaves five). *Defended vs undefended, paired (Fig. 3).* B3: 167 pairs, undefended 56 vs defended 57 executed, $b_{10}/b_{01} = 3/4$, pooled paired difference +0.006 (bootstrap 95% CI -0.024 to $+0.036$). PHASE1-CORE: 168 pairs, 57 vs 57, $b_{10}/b_{01} = 4/4$, difference 0.000 (-0.036 to $+0.036$). Neither defense produced a block in any of the 336 episodes and per-family intervals include zero. These pairs include the episodes the harness labeled `INVALID_NOT_DELIVERED` (the estimand is an executed attacker call for an assigned instance, §8.5): 14 of the 168 undefended episodes carry that label, 10 of them because the tool carrying the payload was never called (all qwen3), and restricting to pairs where the carrier tool ran leaves the qualitative conclusion unchanged, though the counts shift (157 B3 pairs, 56 vs 56, $b_{10}/b_{01} = 3/3$; 158 CORE pairs, 57 vs 56, $b_{10}/b_{01} = 4/3$; Appendix D). PHASE1-CORE, which blocked 36/36 direct-override episodes on the original pack, removed the payload from 0 of 168 partially independent episodes (56 instances $\times$ 3 models). *Nondeterminism floor.* PHASE1-CORE with zero blocks presents essentially the same model input as the baseline, yet 8 of 168 paired outcomes differ at temperature 0 (B3: 7 of 167); differences of that order cannot be attributed to a defense.

6.4 Synthesis

question	evidence
Does the adaptive stack (B3) reduce executed attacks?	No detectable effect in this case study: E2 (66 undefended vs 65 defended; $b_{10}/b_{01} = 2/1$ on 72 pairs), E3 (56 undefended vs 57 defended).
Does PHASE1-CORE?	Only where a literal tool string shared with the detector appears (E2 direct override 0/36); 0/168 removals and no change on partially independent families.
Does a static tool policy stop attacks?	Yes by construction; benign tool tasks fail with it (utility 1.00 $\rightarrow$ 0.33 in E2).
Do the frozen judge-scored tracks measure executed harm?	No: κ 0.16 to 0.36; the Track B classification depends on two offsetting judge errors.
Do measurement choices change conclusions on the same traces?	Yes, demonstrated on this case study's traces (§4). Limited to this testbed; generalization requires independent replication.

Detailed per-family and per-model results for E3 are in Appendix D.

6.5 Held-out application of the rules (MT1 r1)

To test whether the rules are artifacts of the traces they were derived on, we applied them unchanged to an earlier run (MT1 r1: six targets $\times$ four arms on a synthetic single-turn pack; generated before the rules were written down; same project, so not fully independent). Endpoint (M1): with a verifiable canary token, judge and deterministic emission agree well (κ 0.81 to 0.91), so the gap of §6.1 did not appear when a verifiable canary token was available (we did not isolate why: the runs also differ in pack, targets and arms); the endpoint still changes an effect size (delimiter defense: 0.29 judge vs 0.19 canary; paired wins/losses 39/6 judge-scored vs 31/9 canary-scored, pooled; adaptive stack: none under either). Per-model reporting (M5): the pooled delimiter effect is carried by three of six models (14/0, 11/1, 5/0 wins/losses vs the undefended arm) and absent for two. Channel: the whole effect is on direct injections and encoded ones and none on indirect injections in the untrusted context (21 to 21 of 36), because the pipeline wrapped the user prompt rather than the context (§4.7). M2 and M4 could not be tested on this run. [docs/research/SECOND_DATASET_MT1_RULES_20260930.md] A follow-up run (\$0.07, three targets, 180 episodes) that marks the context instead supported the

channel explanation: indirect injections 8 to 1 of 18 (7 wins, 0 losses vs the undefended arm), direct injections unchanged (22 to 22 of 30), benign tasks unharmed; a fresh undefended replicate differed from the earlier undefended run in 8 of 57 attack pairs (14%, judge-scored; 5 of 57, 9%, canary-scored), a larger nondeterminism floor than in the tool harness [docs/research/SPOTLIGHT_CTX_CHECK_20260930.md].

6.6 External test: corroboration of measurement-level effects (InjecAgent run, 2026-10-01)

Scope of this test. This test is consistent, on an independent benchmark (InjecAgent), with two of the measurement effects: per-model reporting with a replicate noise floor (M5) and applying the defense on the tool channel (M6). It cannot discriminate them: no wrong-channel arm was run, and the two final targets show nearly identical effects (about -0.10 each). Its endpoint is proposal level (the first tool call the model emits is the attacker's tool; nothing is executed and arguments are not checked), so it does not test M1's contrast between proposal and execution. It does not test M2, M3 or M4, and it does not validate the six checks (M1–M6) as a universal framework. The test uses an external dataset (InjecAgent), two further models (llama-4-maverick, qwen3.8-flash), and an endpoint that does not depend on our defenses (first tool call is the attacker's

tool). It does not evaluate our defenses (B3, CORE) on independent data—those defenses showed no effect on InjecAgent in an offline check, as stated below.

The protocol was drafted locally (PROTOCOL_EXTERNAL_TEST_DRAFT_v1.md, first committed on 2026-10-01 in 0e64abc with the label "not frozen") before the runner (14404a2) and the results (15b4610) were committed; the run manifest records no start time, so that order rests on commit order in the original history. These three commits could be fetched from the public remote by full SHA but are not reachable from `main`, any branch, tag or pull-request ref; on `main` the protocol and the results

first appear in the transfer commit 6db2971 (2026-10-02). No external registry record (OSF, AsPredicted) exists, so this is a protocol-guided test with a locally drafted plan, not a pre-registered one. Run on the fixed 186-case sample (62 attacker instructions as clusters; sample hash in `experiments/external/injecagent_registered_20261001/MANIFEST.json`; the directory name is historical, the run was not externally registered), temperature 0, endpoint: first tool call is the attacker's tool. Targets are the two that were measurable in the calibration of §6.7; the other targets are classified there and not retested. NOINJ was run on 40 cases. No provider errors occurred.

target	A0 (attacker tool called)	A0 replicate	NOINJ	SPOT_TOOL	SPOT_TOOL minus A0, cluster-bootstrap 95% CI (Holm 98.75% CI)
llama-4-maverick	23/186 (12.4%; Wilson 8.4 to 17.9)	24/186	0/40	5/186 (2.7%)	-0.097 [-0.145, -0.048] [-0.161, -0.038]
qwen3.8-flash	23/186 (12.4%; Wilson 8.4 to 17.9)	22/186	0/40	4/186 (2.2%)	-0.102 [-0.156, -0.054] [-0.172, -0.043]

The replicate differs from A0 by 0.005 (95% CI -0.027 to 0.038) for llama-4-maverick and -0.005 (-0.059 to 0.048) for qwen3.8-flash, which is the run-to-run noise floor at this sample size. Delimiters on the tool channel (SPOT_TOOL) lower the rate of attacker-tool first calls for both targets by about ten percentage points, larger than that floor, and the intervals exclude zero also at the Holm-adjusted level computed over the protocol's four open targets ($\alpha = 0.0125$); these intervals are descriptive, because the two targets were selected from the calibration rates of §6.7 and the protocol was not frozen. The adaptive stack (B3) and the core pipeline (CORE) leave every InjecAgent case unchanged (offline check, `scripts/injecagent_offline_check.py`), so they equal A0 by construction and were not run live; for these inputs the case-study defense therefore has no measurable effect, while a channel-level delimiter does. Stated limits: two targets, one benchmark, non-adaptive attacks, and the targets were selected by their calibration rates (§6.7). The delimiter we used is the plain delimiting variant of spotlighting, which its authors do not recommend over datamarking or encoding because an attacker who knows the delimiters can reproduce them [2403.14720]; the effect is measured on short inputs, and a long-context benchmark reports that delimiters did not lower attack success there (ASR 0.96 against 0.98 undefended on its synthetic tasks) [2608.28411], so the ten-point reduction must not be extended to long contexts or to attackers who know the defense. Hard set test split, the remaining targets and judge tracks are not part of this run, and the executed sample is 186 cases (62 attacker instructions $\times$ 3 contexts) rather than the 124 planned in §5.6 (deviation from §5.6, reason: floor rule and budget).

Reporting rules stated in the locally drafted protocol before the run (their order rests on commit order, not on a registry): results are given per model and per benchmark and never pooled across models; a model with an undefended rate below 5% at $n \geq 40$ is "at the floor, not assessable" and below $n = 40$ "undetermined"; provider failures are reported as failures. The exploratory pilot that informed this design is in Appendix A.

6.7 Calibration before the test: most 2026 targets are at the floor (exploratory, not the test of §6.6)

Moved to the supplement (Section S1, same heading); it is part of this paper.

7 Discussion

What the evidence supports. The most defensible summary is a measurement claim, not a defense claim. The same system yields "supported improvement", "no effect" and "complete stop" depending on choices that are rarely reported: whether success means the model proposed a call or the executor ran it, whether a payload removed before the model counts as a defense outcome or missing data, whether a scenario could be an attack, and who authored the scenarios. Prior audits identified payload non-delivery and tool-identity scoring [2609.32691]; our data add three more that were decisive here.

Why the one favorable result did not transfer. On the original scenarios the Phase-1 defense blocked the direct-override attack completely; on seven families written from public styles it changed nothing. The straightforward reading is that its detector features and the original pack's surface forms coincided — a tool-invocation literal — and that this coincidence, not general detection, produced the effect. In this repository's history such patterns first appear (commit 12414c8, equivalent to the c462945 that an older internal report cites) after the earlier VNEXT confirmation pack and before the Phase-1 holdout and confirmation packs, on the same day (§4.4). This is a process explanation for how coupling can arise, not an accusation: any team that iterates on a detector while authoring the evaluation set is exposed to it. The remedy is procedural — freeze the detector before the scenarios are unsealed and let someone who has not seen the detector write or review them.

Judges. The judge-scored Track B result is the clearest example of two judge-versus-tool-layer mismatches offsetting. The judge scored a denied attack call as success in about half of the denial cases and scored benign tasks as useful when the required tool had been denied. The first understated the defense; the second hid a utility problem. Whether a judge errs in the

direction that flatters the defense or hurts it is not something the reported rates reveal; an execution record is. This does not mean judges are useless: for open-ended harm where no executor exists they may be the only option, but they should then be validated against human labels on the specific configuration [2510.09023, on reward hacking of automated scorers].

Tool policies and the utility cost. A static policy that denies side-effecting tools stops every executed attack in the E2 harness run and, by construction, every benign task that needs those tools. That is the essential trade-off between text-level defenses, which leave the model in control and (on the seven families here) stop nothing, and tool-boundary policies, which are deterministic but only as good as their allowlists [2406.13352 on the tool filter; 2504.11703]. Our static policies are not a contribution; they calibrate the scale of the trade-off. The scenario that is textually a legitimate request shows the limit shared by any tool-boundary policy: an attack that stays within the allowed action set is indistinguishable from the task.

Model-specific susceptibility. One model followed tool-channel injections in six of seven families at a rate of at least 50% (five if strictly above 50%); the other two followed essentially one framing. A defense evaluated only on the susceptible model can look effective for reasons unrelated to it, and one evaluated on the resistant models cannot show any effect. Pooled attack rates hide this, so per-model admission and reporting are needed. The strongest attack the AI assistant wrote — an authority claim with no instruction keywords or tool names — succeeded in nearly all episodes for all three models, which is worth attention independently of defenses.

Practical recommendations—based on this case study.

- (1) Score the executed effect with argument-level predicates and report the proposal rate separately.
- (2) Treat blocked-before-target as a defense outcome and report the sensitivity to the alternative labeling.
- (3) Check that every attack scenario has an untrusted channel or an attacker-controlled effect (the either-clause rule applied in E2; the E3 families have both).
- (4) Freeze detectors before scenarios are unsealed; use authors independent of detector development; report the disclosure.
- (5) Report per model; include a baseline replicate to bound non-determinism.
- (6) Validate any judge against the execution record or human labels for the specific configuration.
- (7) Confirm from the stored request that the defense's transformation reaches the untrusted content and the model as intended; in one pipeline a delimiter defense wrapped the user prompt instead, which reversed where its effect appeared (§4.7). These recommendations are based on this study's findings; independent validation on other harnesses and defenses is needed before they should be adopted as universal practice.

What would strengthen the study—and enable generalization. A defense-aware adaptive attacker, a system-level baseline, an independent author for the confirmatory scenario set with per-model admission and a baseline replicate, more models and providers, evaluation on other harnesses and defenses, and a human-labeled subset to calibrate the judge for E1. Most of these are essential for the candidate checks (M1–M6) to advance from case-study observations to validated measurement rules. We list these as limitations in §8 rather than claim them.

8 Limitations

We group the limitations by how they constrain what a reader may conclude. The first group bounds the claims; the later ones list what we did not do.

8.1 What the results cannot support

No defense claim. Our data do not show that any evaluated defense works. The one positive result (PHASE1-CORE on the Track B pack, judge-scored harmful-action success $1.00 \rightarrow 0.56$, i.e. 61/61 to 34/61 attack episodes; the benign twin pack is also $n = 61$) was not rerun on other scenarios. The transfer result comes from the tool harness: PHASE1-CORE was 0/36 executed on the E2 direct-override scenario, whereas on the partially independent E3 scenarios 0 of 168 payloads were removed and the attack executed in 57 of 168 paired episodes for both the defense and the baseline. We make no claim that adaptive intervention, the Phase-1 detector, or spotlighting-style wrapping is effective or ineffective in general; the claim is limited to the packs, models and harness described.

No adaptive attacker. All attacks are non-adaptive. A defense-aware attacker was explicitly outside the threat model. Prior work reports that detector- and prompt-based defenses are broken by adaptive attacks even when they look strong on static sets [2503.00061; 2510.09023; 2606.15057], so our finding that two such defenses do not help against a *non-adaptive* independent set gives no information about how a stronger defense of the same family would fare, nor about how system-level defenses would fare under adaptive pressure.

No comparison with system-level defenses. We did not implement or run CaMeL-, Progent- or DRIFT-style defenses [2503.18813; 2504.11703]. Our static tool policies (TOOLDENY, ARGALLOW) are hand-written illustrations; they block by construction, and TOOLDENY's large utility cost (benign utility $1.00 \rightarrow 0.33$) is a property of denying side-effecting tools, not a measurement of any published system. ARGALLOW was implemented and unit-tested but never run live, and its allowlists were derived from the benign scenario definitions, so any utility measured on the same benign set would be optimistic by construction.

8.2 Statistical limitations

Small and clustered samples. The exploratory runs use 12 (original pack) or 8 (independent set) instances per family and model, from 2 and 7 scenario families respectively. Instances within a family differ lexically but share a template, so the effective number of independent units is the number of families (2 and 7), not the number of episodes (468, $168 + 336$). The exact McNemar p-values and the Fig. 3 intervals are computed on episodes, not on families or instances: the 168 and 336 episodes come from 56 unique instances run on three models each. Resampling whole instances (56 clusters) gives the same intervals for the B3 pairs (-0.024 to $+0.036$) and CORE pairs (-0.036 to $+0.036$; `scripts/audit_e3_delivery.py`; the audit artifact gives -0.0240 to $+0.0361$ and -0.0357 to $+0.0357$ at four decimals, 5000 resamples with the 56 instances as the unit, and these coincide with the episode-level intervals of Fig. 3 to three decimals); seven family clusters are too few for an interval. These intervals bound the observed difference but are

not equivalence tests (no margin was set), so the results read as no detectable effect, not as proof of no effect; per-cell rates ($n = 8$) have wide intervals. We do not report confirmatory p-values.

Nondeterminism. Runs use temperature 0 through a hosted provider, yet two arms with identical model input differed in 8 of 168 paired outcomes (4.8%; one of the pairs involves a truncated undefended episode, §8.5). Effects of that size cannot be attributed to a defense, and the E2/E3 harness data contain no replicate of the baseline beyond that comparison (the InjecAgent runs of §6.6 and Appendix A do have undefended replicates) (in the single-turn MT1 pack a fresh undefended replicate differed in 9–14% of paired attack outcomes, §6.5). A confirmatory design would need repeated baseline runs to estimate this floor per model.

Exploratory status. The experiments on the multi-turn harness were run before the proposed amendment that fixes the scoring rules (Amendment 10, status *proposed*, not approved). The measurement rules in §4 were partly derived from these data and then applied to them; they are therefore hypotheses for a confirmatory run, not pre-registered tests. Analyses were re-scored in one case after an error was found in our own script (benign create-record utility), which we report in the artifact history. The E2 episode-inclusion rule of §4.2 was likewise adopted after the first analysis; it changed four episodes' inclusion and no conclusion.

8.3 Scenario limitations

Authorship and independence. The independent attack set was authored by an AI assistant at the first author's request. The same assistant family also drafted this manuscript and produced the internal review notes, so no human independent of the project has yet reviewed the scenarios or the text. The assistant had read the repository's Phase-1 detector pattern lists earlier in the same working session while auditing it, so independence from the detector's development is partial. We froze the template file (SHA-256 8ae353ca...9de8) before running any defense on it, wrote from public benchmark styles [2406.13352; 2403.02691], and did not modify the templates after the post-freeze offline replay, but we cannot exclude subtle influence. Confirmation of full independence would require an author who has not seen the detector's implementation or patterns.

Coverage. Seven attack families using four mock tools (`get_weather`, `retrieve_document`, `send_email`, `create_record`), reserved example domains, and English text. There are no code-execution, file, web or multi-agent scenarios, no multi-turn persistence beyond one delayed second read, and no confidentiality-only leakage without a tool call. Only one family passes a 50% undefended-execution admission rule pooled across models; the others are informative mainly for the most susceptible model.

Original pack. One of the two scenarios in the original exploratory set (`create_record_exfil_v1`) is not a valid attack (§4.3) and is excluded from defense claims, which leaves a single valid scenario with a literal tool string shared with the detector's patterns.

8.4 Target and provider limitations

Three open-weight targets (qwen3, gemma, deepseek) reached through one aggregator, with reasoning disabled where the provider allows it; a fourth model (llama) was excluded after a smoke test showed truncation and non-delivery on the provider's route. The record of that smoke test and the exclusion decision exists only in the archive (commit `dfbea801`, not reachable from any ref) and is not verifiable from this tree. The earlier judge-based tracks use one target (qwen-2.5-7b-instruct) and a same-family judge (qwen-2.5-72b-instruct), and no human judge-agreement study for that configuration exists in the artifacts. Comparing the judge with the tool layer's own execution record on the frozen episodes shows weak agreement, with every disagreement in one direction (§6.1); see `docs/research/TRACKS_AB_DETERMINISTIC_RESCORING_20260930.md`. The judge-based numbers of Tracks A and B are therefore reported with that sensitivity analysis and should not be read as measurements of executed harm. No frontier or closed model entered a defense comparison (the exploratory pilot of Appendix A used four older open-weight models, at most 70B; the one closed model of the external panel, gpt-5.6-sol, was scored only in the undefended calibration of §6.7, where it sat at the floor, and was not run in the comparison of §6.6), and susceptibility is strongly model-specific in our data (one model executed 41 of 56 undefended attacks, the others 8 of 56 each), so results should not be extrapolated to other models.

8.5 Artifact and process limitations

Moved to the supplement (Section S1, same heading); it is part of this paper.

8.6 What would change our conclusions

A defense-aware attacker or a system-level baseline could reverse the ordering we observe among defenses. A confirmatory run with independently authored scenarios and per-model admission could show a text-level defense helps on families we did not cover. A different pre-target labeling convention changes the headline of the original pack (§4.2), which is why we require the sensitivity analysis. Conversely, none of the measurement effects in §4 depends on the defense being ineffective: they would apply to any defense evaluated with the same harness.

8.7 Held-out application limits

The held-out application (§6.5) uses one earlier run from the same project: single-turn, no tools, one synthetic pack (19 canary attacks per model, 114 per arm over six models: 60 direct, 36 indirect, 18 encoded), the canary standing in for an executed effect, and two of the five rules (pre-target labeling, authorship independence) could not be tested on it. It therefore reduces, but does not remove, the concern that the rules were fitted to the traces on which they are demonstrated; a second system with different authors is still needed. The wrong-channel finding (§4.7) was supported by a small re-run (18 indirect episodes over three models, one run of the corrected arm), so it is supported but not robustly replicated; the same re-run showed a run-to-run difference of 9–14% of paired attack outcomes at temperature 0 in that pack, and one replicate arm lost six

benign judgements to provider errors.

8.8 Attackers, selection and design choices

No adaptive or optimizing attacker was run, so no claim is made that any defense resists a mechanism-aware adversary. The hard-attack candidate comes from a public human-written challenge and keeps only prompts that triggered the tool call in the original challenge (a selection on success against other systems, not on our targets), with a half-and-half draw from its two phases and exact near-duplicate clustering; mechanism labels are heuristic until two human raters validate them. The model panel and the attack source were chosen after pilot runs

and are reported as pilot-informed, not as independent pre-registration. Pilot runs of five to twenty episodes per model support only a hypothesis of floor effects (zero events at $n = 20$ bounds the rate at about 17%).

Provenance of the Hard set. The human-written part of the Hard set consists of participant submissions to LLMail-Inject; the dataset paper notes that one team generated variants of a template with an LLM [2506.09956], so "human-written" means participant-submitted and selected by tool-call ground truth, not verified to be free of LLM assistance.

9 What the paper may and may not claim

may claim	may not claim
On the frozen Phase-1 pack, judge-scored harmful-action success fell from 1.00 to 0.56; with the tool layer's record it is 6/61 against 61/61, and judge-scored utility 0.967 becomes 0.80	that the defense (or adaptive intervention in general) is effective
The adaptive stack showed no detectable effect in any run	that adaptivity provides a benefit
On seven partially independent families neither detector-style defense changed executed attacks beyond run-to-run noise (paired differences +0.006 and 0.000, intervals include zero)	a general statement about detectors, models or adaptive attackers
Five measurement choices and a channel check changed or qualified conclusions on our own traces	SOTA, production-readiness, or that the rules are validated beyond the two datasets used
A static tool policy stops the tested attacks by construction and removes most benign tool utility	that any published system-level defense (CaMeL, Progent) was evaluated or compared
Delimiters applied to the untrusted context lowered indirect injections from 8 to 1 of 18 in a small re-run	that spotlighting works in general
In an exploratory pilot on 120 independently authored InjecAgent cases (Appendix A; earlier open models, not the final panel), undefended susceptibility ranged from 5/120 to 50/120 and tool-channel delimiters lowered it for one model (26/9 discordant pairs) but not for the larger model of the same family (7/13)	that delimiters, or any tested defense, generalize across models; or anything about frontier or closed models
On InjecAgent (186 cases, two measurable targets), delimiters on the tool channel lowered the rate of attacker-tool first calls (proposal level, nothing executed) by about ten points (12.4% to 2.7% and 2.2%)	that any defense is effective in general, or anything about adaptive attackers, other benchmarks or the targets at the floor

10 Ethics, dual use, AI assistance and reproducibility

Ethics and dual use. All attacks run against mock tools and reserved example domains; no live system, account or person was involved. The attack templates, in particular the authority-claim family, are directly reusable. They are not in the tree of any branch, but both template files are retrievable from the public repository by commit SHA (the original set at `bea82347`, the independent set at `e5135a6`; the retrieved files match the SHA-256 values recorded in `REPRODUCIBILITY.md`), so we do not describe them as withheld or their release as staged. The traces, the frozen packs and the offline analysis scripts are public; the live multi-turn harness (`src/adapti_guard/evaluation/harness_v2/`), the run scripts for E2, E3, the calibration and the external test, and the external-test analysis scripts are not in the tree of any public branch or tag. They exist in two commits of the original history (`1ae0fb4d` and the archive commit `dfbea801`) that can be fetched from the public remote by full SHA but are not reachable from any ref and are not guaranteed to persist; we therefore do not claim that the harness is publicly released. The work is defensive: it improves how defenses are measured. **Use of AI assistance.** An AI assistant was used under the first author's direction in the research-support and writing work: it contributed to analysis code, harness extensions, the independent attack-scenario templates (§8.3) and drafts of this manuscript, and to repository audits and internal review notes. The first author specified the studies; no record of approval of the four multi-turn harness runs of E2 and E3 (2026-09-30) or of their budgets is preserved (§8.5). Numbers

were regenerated from the persisted traces by scripts. The assistant is not an author. The same assistant family wrote the independent scenarios (§8.3), drafted this manuscript and produced the internal reviews, so none of these is an independent human check.

Ledger coverage. `NUMBERS_LEDGER.md` lists 49 quoted strings with their sources; it does not cover every number (for example the E1 kappa values, the Track A/B pattern counts, the multi-turn re-run counts, most of Appendix A, and the §6.6 and §6.7 tables). Appendix C states which tables the one-command script regenerates. **Reproducibility.** The frozen packs carry SHA-256 hashes in `datasets/frozen/*/hashes.sha256`; the run manifests of the multi-turn runs record commit SHAs, not file hashes, and the template files' SHA-256 values are given in `REPRODUCIBILITY.md` (the template files themselves are not in the tree); the E1 to E4 tables and figures are regenerated by a script from committed traces (`scripts/rescore_tracks_ab_deterministic.py`, `scripts/analyze_harness_v2_exploratory.py`, `scripts/analyze_independent_defended.py`, `scripts/apply_rules_second_dataset_mt1.py`, `scripts/analyze_spotlight_ctx_check.py`, `scripts/make_fig{1,2,3}_*.py`); a number ledger (`NUMBERS_LEDGER.md`) lists each quoted number with its source. The external-test numbers of §6.6 and §6.7 are read from committed per-episode and derived records; their runner and analysis scripts are not public, so those numbers cannot be regenerated from this repository, and the archive of the original history (`case-study-v1`) is not published as a tag. Hosted models change and temperature 0 is not deterministic (measured), so traces, model identifiers and dates are released rather

than relying on reruns. Live spend is reported per experiment in §5 and §8.5.

11 Conclusion

This paper reports an empirical methodological case study on one testbed. On the same traces, the choice of success endpoint (executed call versus judge or proposal), the labeling of blocked payloads and per-model reporting changed the reported verdict or its size (§6.1–§6.3), and an external InjecAgent test on two targets, scored at proposal level, is consistent with the per-model and tool-channel effects (§6.6). Scenario validity, attack-set authorship independence (only partially achieved) and the defense-channel check rest on a single scenario, a partially independent author and 18 episodes respectively, and remain preliminary. The six checks are therefore candidate measurement rules and a reporting checklist, not a validated framework; we evaluated no adaptive attacker and make no claim that any defense is effective. Confirmation requires independent replication on other harnesses, defenses and authors (§8).

References

Reading status: on 2026-10-01 every cited claim and number below was checked against the PDF of the cited paper (per-claim table in `docs/paper/negative_result/REFERENCE_VERIFICATION_20261001.md`). Several cited works are preprints or workshop papers that are not peer reviewed (Shaw, Pathade et al., Narisetty et al., Deep et al., Akinrele and Gowda, Arman et al.).

References

[2406.13352] Debenedetti et al. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents.

[2403.02691] Zhan et al. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated LLM Agents.

[2503.18813] Debenedetti et al. Defeating Prompt Injections by Design (CaMeL).

[2504.11703] Shi et al. Progent: Securing AI Agents with Privilege Control.

[2503.00061] Zhan et al. Adaptive Attacks Break Defenses Against Indirect Prompt Injection Attacks on LLM Agents.

[2510.09023] Nasr et al. The Attacker Moves Second: Stronger Adaptive Attacks Bypass Defenses Against LLM Jailbreaks and Prompt Injections.

[2606.15057] Ma et al. AutoDojo: A Generative Benchmark for Evaluating Prompt Injection Defenses in LLM Agents.

[2606.26479] Narisetty et al. Adaptive Evaluation of Out-of-Band Defenses Against Prompt Injection in LLM Agents.

[2609.32691] Shaw. Silent Failures in Agentic Security Evaluation: A Validated Harness for Tool-Call Mediation Under Indirect Prompt Injection (full text).

[2502.05174] Zhu et al. MELON: Provable Defense Against Indirect Prompt Injection Attacks in AI Agents (ICML 2025).

[2412.16682] Jia et al. The Task Shield: Enforcing Task Alignment to Defend Against Indirect Prompt Injection in LLM Agents.

[2312.14197] Yi et al. Benchmarking and Defending Against Indirect Prompt Injection Attacks on Large Language Models (BIPIA; KDD 2025; read).

[2506.09956] Abdelnabi et al. LLMail-Inject: A Dataset from a Realistic Adaptive Prompt Injection Challenge (read; MIT license).

[2608.28411] Liu et al. LongPIBench: A Long-Context Benchmark for Prompt Injection (read).

[2605.30454] Arman et al. The Surface You Test Is Not the Surface That Breaks (read).

[2606.10525] Hofer, Debenedetti and Tramèr. Assessing Automated Prompt Injection Attacks in Agentic Environments (read).

[2605.26999] Akinrele and Gowda. Prompt Injection Detection is Regime-Dependent: A Deployment-Aware Evaluation with Interpretable Structural Signals (read).

[2604.23887] Deep et al. Evaluation of Prompt Injection Defenses in Large Language Models (vendor study; read).

[2609.25173] Pathade, Pawar and Patil. Attack Success Rate Is Not a Number: On Measurement Validity in Agentic AI Security Evaluation.

[2603.15714] Dziemian et al. How Vulnerable Are AI Agents to Indirect Prompt Injections? Insights from a Large-Scale Public Competition.

[2609.36817] Ying et al. (Tencent Zhuque Lab). pikit: A Composable Toolkit for Indirect Prompt Injection Research and Evaluation.

[2604.08499] Geng et al. PIArena: A Platform for Prompt Injection Evaluation.

[2403.14720] Hines et al. Defending Against Indirect Prompt Injection Attacks With Spotlighting.